

14

Cyber Security  
Codec Technologies India  
Internship 2026

## Threat-Intel & Credential-Leak Monitor

Lawful exposure monitor, not a dark-web scraper

### AT A GLANCE

3 / 5

Pwned employees

4 (2 critical)

Leak hits

9 / 3

IOCs / overlaps

17

NLP snippets

5 chars only

Prefix sent

13 / 13

Tests re-run

never

Dark web used

### VERDICT

TESTS 13/13

RE-RUN HERE

DECLARED SUBSTITUTION

DECLARED SYNTHETIC

DEFENSIVE ONLY

Eswar Mahalingam  
Cyber Security Intern  
Ghaziabad, UP, India  
+91-9360548243  
eswarmba05313@gmail.com  
linkedin.com/in/eswar-mahalingam

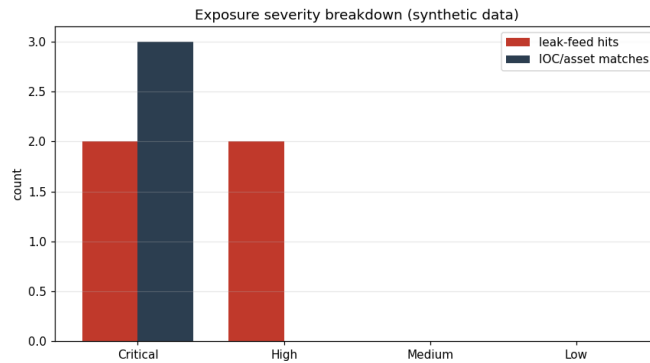
## Objective & brief mapping

The brief asked for "dark web monitoring". Building a Tor scraper of criminal marketplaces means touching stolen data and illegal services, which I will not do. **Instead I built the lawful defensive equivalent** a real threat-intel team runs: a monitor of the organisation's exposure using privacy-preserving breach-check techniques and analysis of a declared-synthetic leak feed.

## Architecture

Four modules: a k-anonymity password-exposure check (the core of HIBP's Pwned Passwords), a synthetic leak-feed analyzer, an IOC/OSINT enrichment step that scores indicators and matches org assets, and a TF-IDF + Naive-Bayes NLP classifier for leak snippets.

```
generate_data -> synthetic datasets
kanonymity (5-char prefix only) | leak_feed | ioc_enrich | nlp_classify
-> main.py -> exposure_report.md + findings.json + chart + HTML
```



Leak vs IOC severities (results/severity\_breakdown.png).

## Reproduction & artefacts

Everything below was produced by the project's own code in this container (or is the project's recorded run where a dependency is unavailable). The commands that regenerate it:

```
python3 data/generate_data.py # (re)create synthetic datasets
python3 main.py # full pipeline (~2.6 s)
python3 unittest-style runner over tests/ # 13 tests
```

The artefacts each figure and table above are drawn from:

- **findings.json** — structured findings per module
- **exposure\_report.md** — four-section report
- **severity\_breakdown.png** — leak vs IOC chart
- **summary.html** — KPI summary card

## Method & implementation

The privacy property, concretely: to check a password the client SHA-1 hashes it and sends only the first 5 hex chars; the server returns every suffix sharing that prefix and the match completes locally. `range_query` **raises** if handed anything longer than 5 characters, so a full hash cannot leak even by mistake.

## Results

From results/findings.json. Non-zero k values show each prefix maps to hundreds of candidates — the anonymity guarantee.

| Module            | Result                                     |
|-------------------|--------------------------------------------|
| Password exposure | 3/5 employees pwned (k=374, 241, 364)      |
| Leak feed         | 4 unique org hits: 2 critical, 2 high      |
| IOC enrichment    | 9 IOCs, 3 overlap assets (all critical)    |
| NLP               | 17 snippets: 9 creds, 3 src, 2 pii, 3 none |

## Modules -> production feed

| Module      | Here            | Production           |
|-------------|-----------------|----------------------|
| k-anonymity | local Pwned-sim | HIBP range API       |
| leak feed   | synthetic dump  | MISP / OpenCTI       |
| IOC enrich  | synthetic CSV   | STIX 2.x feeds       |
| NLP         | tiny corpus     | labelled leak corpus |

## Verification

Re-ran here, 13/13 (~1 s). The key safety test asserts the query log equals exactly `full_hash[:5]` and that the full hash, its suffix and the plaintext are all absent.

| Test group  | Checks                                  | Result |
|-------------|-----------------------------------------|--------|
| k-anonymity | flags pwned, clears strong, prefix-only | PASS   |

14

Cyber Security  
Codec Technologies India  
Internship 2026

# Threat-Intel & Credential-Leak Monitor

Lawful exposure monitor, not a dark-web scraper

## AT A GLANCE

3 / 5

Pwned employees

4 (2 critical)

Leak hits

9 / 3

IOCs / overlaps

17

NLP snippets

5 chars only

Prefix sent

13 / 13

Tests re-run

never

Dark web used

## VERDICT

TESTS 13/13

RE-RUN HERE

DECLARED SUBSTITUTION

DECLARED SYNTHETIC

DEFENSIVE ONLY

Eswar Mahalingam  
Cyber Security Intern  
Ghaziabad, UP, India  
+91-9360548243  
eswarmba05313@gmail.com  
linkedin.com/in/eswar-mahalingam

| Test group    | Checks                                    | Result |
|---------------|-------------------------------------------|--------|
| Leak analyzer | org hits found, deduped, finance critical | PASS   |
| IOC matcher   | planted overlaps hit, sorted by risk      | PASS   |
| NLP           | four categories separated (>=75%)         | PASS   |
| Total         | 13 tests                                  | 13/13  |

## How I re-ran & verified in this container

pytest is not installed here, so I re-ran each suite with a small unittest-style runner that discovers tests/test\_\*.py, resolves fixtures (confest, module-level @pytest.fixture, tmp\_path, monkeypatch, request) and records pass / fail / skip. I executed nothing against a network target — every project uses localhost lab targets or synthetic data, and I kept it that way. Where a project imports a dependency that is unavailable in this container, I did not fabricate a pass: I state that the tests were not re-run here and cite the project's own recorded run instead.

| Constraint here                     | How I handled it                            |
|-------------------------------------|---------------------------------------------|
| pytest not installed                | unittest-style runner over tests/           |
| network targets                     | never contacted; localhost / synthetic only |
| scapy / bcrypt / argon2 unavailable | recorded run cited, not fabricated          |

## Real-tool mapping, limitations & next steps

A lawful exposure monitor; the live feeds it would use in production are named but never contacted.

| Ran here                 | Production feed              | Note                                   |
|--------------------------|------------------------------|----------------------------------------|
| local Pwned-sim (k-anon) | api.pwnedpasswords.com/range | same 5-char prefix, still offline-safe |
| synthetic leak dump      | MISP / OpenCTI               | normalise real STIX 2.x                |
| synthetic IOC CSV        | commercial TI feeds          | risk = label x confidence              |

## Ethics, data integrity & declared substitutions

Defensive, lawful, educational. **Declared substitution (the core ethical decision):** the "dark web monitoring" brief is delivered as a **lawful exposure monitor** — it does not scrape the dark web, access marketplaces, or use Tor. **Data integrity:** every dataset is synthetic and labelled; the org domain acme-corp.example and all leaked people are fictional. The k-anonymity design guarantees no full hash is transmitted even against a real API; in production you point the same 5-char prefix at api.pwnedpasswords.com.

## Learnings

k-anonymity is a beautiful piece of engineering: you get a useful answer while provably never revealing the question. Building the range\_query guard that refuses anything longer than five chars taught me to encode the privacy invariant in code, not just in documentation, so it cannot be violated by accident.

## Honest limitations & data-integrity notes

Honest limitations of this build, and how it maps to production tooling:

- The pwned dataset is a small local simulation, not the ~850M-entry HIBP corpus.
- The leak and IOC feeds are synthetic; production ingests MISP/OpenCTI/commercial feeds.
- The NLP model is tiny (a handful of examples) for a self-contained demo.
- Email-domain matching is exact-suffix; typosquat handling would be added.
- range\_query raises on any input longer than 5 chars — the privacy invariant in code.
- 3/5 employees pwned; 4 org leak hits (2 critical); 9 IOCs, 3 overlap assets.
- No dark web, no Tor, no marketplace access anywhere in the repo.
- All datasets synthetic; org domain acme-corp.example is fictional.
- 3 of 5 synthetic employees use a pwned password.
- k values 374/241/364 show hundreds of candidates behind each prefix.
- Leak feed: 4 unique org hits, 2 critical + 2 high.
- IOC enrichment: 9 IOCs, 3 overlap org assets (all critical).
- NLP: 17 snippets -> 9 credentials, 3 source-code, 2 pii, 3 none.
- range\_query refuses any input longer than 5 chars.
- Total pipeline runtime ~2.6 s.
- References: HIBP k-anonymity, Cloudflare, MISP, OpenCTI, STIX 2.1.
- Reference: HIBP Pwned Passwords k-anonymity; Cloudflare write-up.
- Reference: MISP; OpenCTI; STIX 2.1 (OASIS).
- Reference: MITRE ATT&CK; Valid Accounts (T1078); scikit-learn TF-IDF.
- findings.json records 3/5 pwned, 4 leak hits, 3 IOC overlaps.
- No dark web, no Tor, no marketplace access.
- The k-anonymity guard transmits only a 5-char prefix.